

Intrusion Detection System (IDS)

By: Kabita Dhital

6TH SEM

BSc. CSIT

- An **Intrusion Detection System (IDS)** is a security system that monitors network traffic or computer systems to detect suspicious, malicious, or unauthorized activities.
- When an IDS detects a possible attack, it **generates an alert** to notify the system administrator or security team.
- An Intrusion Detection System (IDS) is a security tool that monitors network traffic or system activities to detect unauthorized access or suspicious behavior.
- Think of it as a "watchdog" that looks for signs of cyber attacks or security breaches, helping administrators respond quickly before damage occurs.
- Detects threats such as malware, port scanning, DoS/DDoS attacks and brute-force attacks.
- Supports both Host-based IDS (HIDS) and Network-based IDS (NIDS).
- Uses signature-based, anomaly-based and behavior-based methods to detect threats.
- Generates alerts and logs that help security teams investigate and respond to incidents.

Simple Example

Imagine a **security guard** at the entrance of a building:

- The guard watches everyone entering the building.
- If a suspicious person tries to enter, the guard detects it.
- The guard raises an alarm.
- However, the guard may not physically stop the person.

Similarly, an **IDS monitors computer systems and raises an alert when it detects possible attacks.**

Type	Description
Network-based IDS (NIDS)	Monitors network traffic to detect attacks.
Host-based IDS (HIDS)	Monitors activities on an individual computer or server.
Signature-based IDS	Detects attacks by matching known attack patterns or signatures.
Anomaly-based IDS	Detects unusual behavior that differs from normal activity.
Hybrid IDS	Combines multiple detection techniques.

Types of Intrusion:

External Attacks

- **Break-in attempts:** Trying to guess passwords or force entry into a network.
- **Denial of service:** Flooding a system with traffic so real users cannot access it.

Internal Attacks

- **Masquerading:** Pretending to be another user to steal data or blame someone else.
- **Misuse of privilege:** Using normal access rights to do things you should not do.
- **Malicious action:** Intentionally destroying files or stealing private company information. [[1](#), [2](#), [3](#), [4](#), [5](#)]

Clandestine User

- **Bug exploitation:** Finding errors in programs that have high power or special rights.
- **Hidden access:** Using those program flaws to take control without getting caught.

IDS vs IPS

- **IDS:** Detects and **alerts** about suspicious activity.
- **IPS (Intrusion Prevention System):** Detects and **actively blocks** suspicious activity.

Common Attacks Detected by IDS

- **DoS/DDoS Attacks**
Attackers send a huge amount of traffic or requests to a server or network to make the service unavailable to legitimate users.
- **Malware**
IDS can detect suspicious network activities related to malicious software such as **viruses, worms, Trojans, and ransomware**.
- **Port Scanning**
Attackers scan the ports of a system to find open ports and identify available services that may be vulnerable to attack.
- **Brute-Force Attacks**
Attackers repeatedly try different usernames and passwords to gain unauthorized access to an account or system.
- **Unauthorized Access**
IDS detects attempts by unauthorized users to access systems, networks, files, or resources.
- **SQL Injection**
Attackers insert malicious SQL commands into application inputs to access, modify, or delete information stored in a database.
- **Network Probing**
Attackers examine a network to discover active devices, services, operating systems, and potential vulnerabilities before launching an attack.

Intruder:

- An intruder is a person who attempt to gain unauthorized access to a system, to damage the system or to disturb the data in the system.
- The main goal of this person is to violate the security of the system by interfering with system availability, data integrity or data confidentiality.
- Intruder are often related to hackers or cracker. Intruder attack range from the benign to serious.
- At the benign end, the attack may be simply to explore the internet or local system and see what is out there.
- At the serious end the attack may be attempting to read privileged data, perform unauthorized modification of data or disrupt the system.

Types of Intruder:

- **Masquerader:** an individual who is not unauthorized to use the system but act as authorize user to penetrate a system's access control to exploit a legitimate user's account. A masquerader is likely to be an outsider.
- **Misfeisor:** a legitimate user who accesses data, program or resources for which such access is not authorize or which is authorize for such but misuse privilege. The misfeisor is generally insider.
- **Clandestine User:** an individual who seizes supervisory control of the system and uses this control to evade auditing and access control or to surpass audit collection. The clandestine user can be either outsider or insider.

Intrusion Techniques:

Intrusion techniques are the methods or approaches used by attackers to **gain unauthorized access to a computer system, network, or data.**

The common intrusion techniques are:

- **Password Cracking**

Attackers try to guess or discover a user's password using techniques such as brute force or dictionary attacks.

- **Phishing**

Attackers send fake emails, messages, or websites to trick users into revealing sensitive information such as usernames and passwords.

- **Spoofing**

The attacker pretends to be a trusted person or system by using a fake IP address, email address, or identity.

- **Malware Attack**

Attackers use malicious software such as viruses, worms, Trojans, and ransomware to damage or gain unauthorized access to systems.

- **Denial-of-Service (DoS)**

The attacker floods a system or network with excessive requests, making the service unavailable to legitimate users.

- **Man-in-the-Middle (MITM)**

The attacker secretly intercepts communication between two parties to steal or modify information.

- **Privilege Escalation**

An attacker who has gained limited access attempts to obtain higher-level privileges, such as administrator access.

- **Social Engineering**

Attackers manipulate or deceive people into providing confidential information or access to systems.

Overview of Intrusion Detection System (IDS) :

Computer system that are not under attack exhibits several characteristics:

- The action of the users and processes generally conform to a statistically predictable pattern. For example, a user who use only word processing when using a computer is unlikely to perform a system maintenance function.
- The action of the users and processes do not include sequence of command to subvert the security policy of the system. In practice only sequences known to subvert the system can be detected.
- The action of the process conforms to a set of specifications describing actions that the processes are allowed to do.

The system that are under attack fail to meet at least one of these characteristics.

Goals of intrusion detection:

Detecting a wide variety of intrusion like intrusion from within the site as well as those from outside the site, both known and previously unknown attacks should be detected. This suggest a mechanism for learning or adapting to new types of attacks or to changes in normal user activity.

Detecting an intrusion in a timely fashion. It suffices to discover an intrusion within a short period of time so that the damage from any intrusion can be reduced.

Present the analysis in a simple, easy to understand format.

Be accurate: A false positive occur when an intrusion detection system reports an attack, but no attack is underway. This will reduce the confidence in the correctness of the results as well as increase the amount of work involved. However, the false negative occurring when an intrusion detection system fails to report an ongoing attack are worse because the purpose of the IDS is to report attacks. The goal of the intrusion detection system is to minimize both type of error.

Intrusion Detection Model: Intrusion detection system determines if action constitute intrusion or not on the basis of one or more models of intrusion.

A model classifies a sequence of action or state or a characterization of state or action as “good” (no intrusion) or “bad” (possible intrusion).

Some of the models are:

1. **Anomaly Modeling:** This model uses a statistical characterization and action or state that are statistically unusual are classified as bad. Anomaly detection uses the assumption that unexpected behavior is evidence of an intrusion. Anomaly detection analyzes a set of characteristics of the system and compares their behavior with a set of expected value. Expected behavior can be characterize by some set of metrics like threshold metric, statistical moments etc.
2. **Misuse Modeling:** This model compares action or states with known sequence to indicate intrusion and classified those sequence as bad. In the context of intrusion detection system, when the attack is done by insider or authorize user it means “rule base detection”. Misuse detection determines whether a sequence of instruction being executed is known to violate the site security policy being executed. If so, it reports a potential intrusion. Modeling of misuse requires a knowledge of system vulnerabilities or potential vulnerabilities that attacker attempts to exploit. The IDS incorporates this knowledge into rule set.

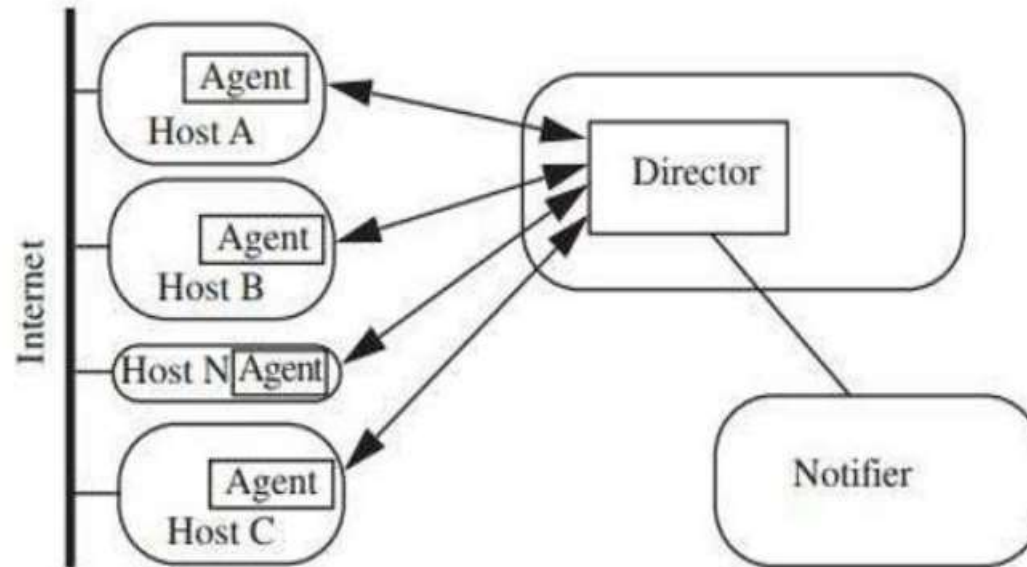
Working mechanism:

- When a data is passed to the IDS, it applies the set of rule on data to determine if any sequence of data match any of the rule.
- If so, it reports that a possible intrusion is underway.

Misuse based IDS often use expert system to analyze the data and apply the set of rule set. These system cannot detect attacks that are unknown to rule set's developer. Previous unknown attack or variation of known attack are difficult to detect using expert system. Later, IDS used adaptive method involving neural network to improve their detection abilities.

3) Specification Modeling: Specification based model classify states that violate the specification as bad. Specification based detection determines whether or not a sequence of instruction violated a specification of how a program or system should execute. If so, it reports a potential intrusion. For security purpose only those programs that in some way change the protection state of the system need to be specified and checked.

Architecture of Intrusion Detection System (IDS):



An **Intrusion Detection System (IDS)** is an **automated auditing mechanism** used to monitor computer systems and networks, detect suspicious activities, and notify the administrator about possible security violations.

1. Agent

- An **Agent** is responsible for **collecting information** from the target system or network. It acts like a **logger or sensor**.
- The agent:
 - Collects data from computers, networks, log files, or other sources.
 - Monitors the system for suspicious activities.
 - Filters out irrelevant information.
 - Sends important information to the **Director** for analysis.
- **Example:** If the agent needs to detect failed login attempts, it checks the login log file, ignores successful login records, and sends only failed login information to the Director.
- **Types of Information Gathering**

a) Host-Based Information Gathering (HIDS)

Host-based agents collect information from a specific computer or server.

- They use:
 - System logs
 - Application logs
 - Security logs
 - Accounting logs
- They can also monitor the current state of a system and generate their own records.

Example: Monitoring repeated failed login attempts on a server.

b) Network-Based Information Gathering (NIDS)

Network-based agents monitor **network traffic** using various devices and software.

- They can detect:
- Denial-of-Service (DoS) attacks
- Flooding attacks
- Network scanning
- Suspicious network traffic
- They may use **network sniffing** to examine packets traveling through the network.

c) Combining Sources

An agent can combine information from **multiple hosts, logs, and network sources**. This provides the Director with a broader view of the system and helps identify possible security violations.

2. Director (Analyzer)

- The **Director**, also called an **Analyzer**, receives information from the agents and analyzes it to determine whether an intrusion or attack is occurring.
- The Director:
- Removes unnecessary and duplicate records.
- Correlates information from multiple sources.
- Uses an analysis engine to identify suspicious activities.
- Determines whether a security violation or attack is taking place.

- The Director is often placed on a **separate system** to make it more difficult for attackers to manipulate or evade the IDS.
- **Example:** If several agents report multiple failed login attempts from the same source, the Director can correlate this information and identify a possible **brute-force attack**.

3. Notifier

- The **Notifier** receives the results from the Director and takes the appropriate action.
- It may:
 - Send an alert to the security administrator.
 - Display a warning message.
 - Generate a security report.
 - Provide a graphical representation of the detected attack.
 - In some IDS, initiate an appropriate response to the attack.
- **Example:** If the Director detects a possible attack, the Notifier may display "**Intrusion Detected**" or send an alert to the system administrator.

Easy Real-Life Analogy

- Think of an IDS as a **building security system**:
- **Agent = Security Camera:** Observes and collects information.
- **Director = Security Control Room:** Analyzes camera footage and identifies suspicious behavior.
- **Notifier = Alarm System:** Alerts the security guard when an intrusion is detected.